


# TED UNIVERSITY

## CMPE491 Senior Project

## BioAuth Project High-Level Design Report

## 13.05.2026

**Team Members:**

Esra Eda Kılıç - Computer Engineering
Enes Taşçı - Computer Engineering
Ömer Taylan Alemdar - Computer Engineering
Batuhan Mert Korkmaz - Computer Engineering

**Supervisor:**

Dr. Ulaş Güleç

**Jury Members:**

Prof. Dr. Saiful Islam
Prof. Dr. Tolga Kurtuluş Çapın

**1. Introduction....3**
1.1 Purpose of the System.... 4
1.2 Design Goals....5
1.3 Definitions, Acronyms, and Abbreviations.... 6
1.4 Overview....7
**2. Current Software Architecture....7**
**3. Proposed Software Architecture....8**
3.1 Overview....8
3.2 Subsystem Decomposition....9
3.3 Hardware/Software Mapping....10
3.4 Persistent Data Management....11
3.5 Access Control and Security....11
3.6 Global Software Control....11
3.7 Boundary Conditions....12
**4. Subsystem Services.... 13**
4.1 Authentication and Communication Services.... 13
4.2 Physiological Analysis Services....13
4.3 Verification and Monitoring Services....13
**5. Glossary.... 14**
**6. References....15**

# 1. Introduction

The high-level design of the BioAuth system, a physiological liveness-aware biometric authentication platform created to enhance the security and dependability of remote identity verification systems, is presented in this report. To strengthen defense against contemporary spoofing attacks like replay attacks, AI-generated portrait animations, and deepfake-based identity fraud, the system combines conventional facial similarity verification with remote photoplethysmography (rPPG)-based physiological liveness detection.

This report's goal is to explain how the project's analysis and requirement models are converted into a structured system architecture. The system's overall architectural structure, subsystem decomposition, technology choice, deployment structure, global control flow, and key design techniques employed during the development process are all highlighted in the report.

The BioAuth system is made up of several separate but connected subsystems that are in charge of real-time camera processing, face analysis, physiological signal extraction, liveness assessment, facial similarity verification, and decision fusion. It is intended to be a modular and scalable authentication platform. While maintaining compatibility with widely accessible consumer hardware like webcams and smartphone cameras, the design places a high priority on maintainability, extensibility, real-time performance, and secure handling of biometric data.

The main design objectives, architectural choices, and system-level factors that direct the BioAuth platform's implementation are also explained in this document. The report also offers a summary of the software components, deployment techniques, and technologies used to implement the system architecture.

## 1.1 Purpose of the System

The BioAuth system's goal is to offer a dependable and safe method for remote biometric identity verification. To increase resistance against contemporary spoofing attacks, the system combines conventional facial verification with physiological liveness detection based on remote photoplethysmography (rPPG).

Traditional authentication methods primarily depend on facial similarity and basic visual cues like head movements or blinking. However, these methods are now more susceptible to replay and synthetic identity attacks due to recent advancements in deepfake and AI-generated portrait animation technologies.

BioAuth addresses this problem by analyzing subtle skin color variations caused by real blood circulation using standard cameras. By combining physiological liveness analysis, facial similarity verification, and input quality validation, the system aims to distinguish real users from spoofed or AI-generated presentations more effectively.

The project also aims to demonstrate that advanced biometric security mechanisms can be implemented using commonly available hardware such as webcams and smartphone cameras without requiring specialized biometric sensors.

BioAuth sets itself apart from current systems in a number of ways. Commercial solutions either need specialized hardware, like depth or infrared sensors, or rely on active liveness challenges that are susceptible to generative AI attacks. BioAuth makes advanced biometric security available without the need for extra hardware by achieving passive physiological liveness detection with just standard RGB cameras. Additionally, replacing traditional binary classification with a three-outcome decision model (Accept, Reject, Retry) is a purposeful design innovation that enhances user experience in real-world scenarios while preserving security integrity.

## 1.2 Design Goals

The design of the BioAuth system is guided by several architectural and security-oriented goals. Each goal reflects a deliberate trade-off analysis performed during the design process.

- **Robustness Against Spoofing:** Through physiological liveness analysis, the system is built to identify and fend off contemporary presentation attacks, such as print attacks, replay attacks, and AI-generated deepfake portrait animations. BioAuth analyzes subtle hemodynamic signals that are impossible for synthetic media to replicate, in contrast to traditional systems that only use visual challenges. Due to the growing sophistication of generative attack tools, this decision was made despite the additional processing complexity it introduces.

- **Low Latency and Real-Time Performance:** The system strives to generate a final authentication decision in three to five seconds, with a minimum capture rate of thirty frames per second. The choice of lightweight signal processing algorithms (CHROM and POS) over more computationally costly deep learning options for rPPG extraction was directly impacted by this limitation. Here, real-time feasibility on common hardware is traded off for a possible decrease in signal robustness under extremely difficult lighting conditions.

- **Graceful Degradation:** In order to prevent legitimate users from being mistakenly rejected in unfavorable circumstances like dim lighting, excessive motion, or erratic camera input, the system introduces a third terminal state called Retry. It was decided against lowering authentication thresholds to make up for poor input because doing so might make spoofing attacks less effective.

- **Privacy and Regulatory Compliance:** Without express user consent, all biometric inputs (including rPPG signals and video frames) are only processed in volatile memory and are never permanently stored. This design decision promotes adherence to GDPR and KVKK data protection regulations. Every authentication necessitates a fresh live capture procedure because biometric data is not saved between sessions.

- **Modularity and Scalability:** The system is broken down into separate subsystems with distinct interfaces. In order to facilitate independent testing of individual components, ease maintenance, and accommodate future extensions like more liveness modalities or different face embedding models, this architectural choice was made over a monolithic pipeline design.

- **Hardware Accessibility:** Without the need for specific biometric sensors, the system is purposefully made to function on common webcams and smartphone cameras. This objective was given top priority in order to optimize deployment accessibility. The QualityAssessor subsystem and the Retry mechanism manage the acknowledged trade-off that signal quality may differ between camera hardware.

## 1.3 Definitions, Acronyms, and Abbreviations

- **rPPG:** Remote Photoplethysmography, a non-contact technique used to extract physiological pulse signals from facial video by analyzing subtle skin color variations.
- **CHROM:** Chrominance-based rPPG extraction algorithm used to isolate pulse-related color changes from RGB signals.
- **POS:** Plane Orthogonal to Skin, an rPPG signal extraction method based on skin-tone orthogonal projection.
- **SNR:** Signal-to-Noise Ratio, a metric used to evaluate the quality and strength of the extracted physiological signal.
- **PAD:** Presentation Attack Detection, the process of determining whether a biometric sample belongs to a real user or a spoofing attempt.
- **APCER:** Attack Presentation Classification Error Rate, the proportion of attack samples incorrectly classified as genuine.
- **BPCER:** Bona Fide Presentation Classification Error Rate, the proportion of genuine user samples incorrectly classified as attacks.
- **FFT:** Fast Fourier Transform, a frequency-domain analysis method used to identify dominant physiological pulse frequencies.
- **ROI:** Region of Interest, selected facial areas such as the forehead and cheeks used for physiological signal extraction

### 1.4 Overview

This report describes how the BioAuth system evolved from its problem domain to a high-level software architecture that is formalized. The system is built as a modular biometric authentication platform made up of linked subsystems that are in charge of liveness assessment, physiological signal extraction, real-time face analysis, and the creation of authentication decisions.

Operating on widely accessible hardware, including webcams and smartphone cameras, the architecture facilitates secure biometric data handling, scalability, maintainability, and real-time processing.

Section 2 assesses the shortcomings of existing authentication methods and the rationale for the suggested strategy. The overall system architecture, subsystem breakdown, hardware/software platform selection, and key design approaches are all presented in Section 3. Section 4 outlines the system's API-level services and subsystem responsibilities.

## 2. Current Software Architecture

Identification document capture with OCR-based text extraction, live camera frame acquisition, active liveness challenge execution (e.g., blinking, head rotation, or smile detection), and final facial similarity matching against the captured document photo are the four main stages of the sequential pipeline used by most current remote identity verification systems.

This approach's architectural limitation is its sole dependence on behavioral and visual cues. The system is predicated on the idea that a person must be physically present in order to replicate actions like blinking or turning the head. But with today's generative AI tools, this presumption is no longer valid. Attackers can pass visual liveness tests without the presence of a live person thanks to portrait animation models like LivePortrait, which can create realistic facial movements from a single static image.

Additionally, no physiological signal coming from the user is analyzed by current systems. There is no way to confirm that the face is a biological organism, that blood is flowing beneath the skin, or that the video stream is coming from a live camera instead of a pre-recorded or injected feed. Conventional architectures thus fail to detect replay attacks, deepfake video injections, and synthetic identity presentations.

Instead of using visual similarity as the only verification criterion, physiological liveness analysis is proposed as a core authentication layer in the BioAuth system to address these structural vulnerabilities.

# 3. Proposed Software Architecture

## 3.1 Overview

BioAuth proposes a hybrid biometric authentication system that augments conventional facial similarity verification with rPPG-based physiological liveness detection. A fusion engine integrates liveness scores, facial similarity, and quality metrics to yield a final decision.

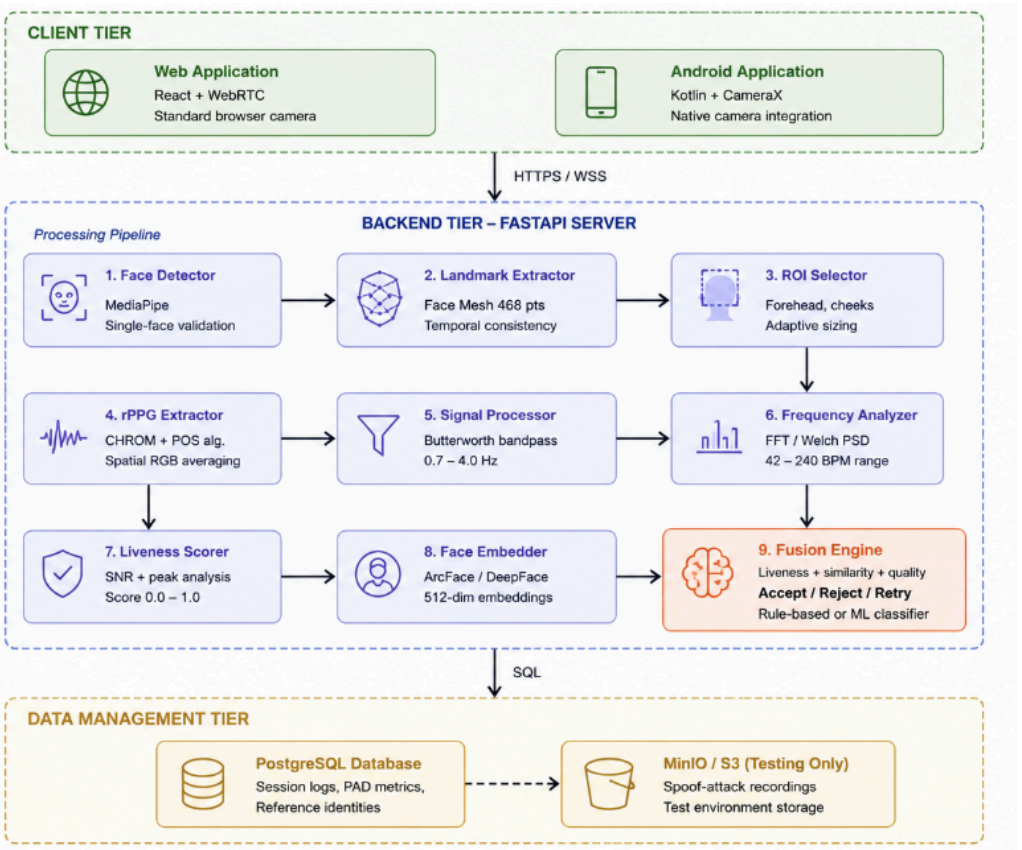



*Figure 1 System Architecture Diagram of the BioAuth Platform*

The BioAuth platform's high-level system architecture is shown in Figure 1. The client tier, backend processing tier, and data management tier are the three main tiers that make up the architecture. Through HTTPS/WebSocket connections, client apps interact with the FastAPI backend, which handles identity verification, signal processing, facial analysis, and rPPG extraction. While PostgreSQL stores non-biometric session metadata and PAD-related evaluation results, the Fusion Engine combines liveness, similarity, and quality metrics to produce the final authentication decision.

### 3.2 Subsystem Decomposition

During system design, the system was decomposed into the following interacting subsystems:

- **CameraCapture:** Manages real-time camera initialization and frame buffering.
- **FaceDetector & LandmarkExtractor:** Utilizes MediaPipe to detect faces and extract anatomical key points for Region of Interest (ROI) mapping.
- **ROISelector:** Dynamically crops isolated patches (forehead, cheeks) for signal derivation.
- **RPPGExtractor & SignalProcessor:** Applies CHROM and POS algorithms to spatial RGB averages, followed by Butterworth bandpass filtering (0.7–4.0 Hz).
- **FrequencyAnalyzer & LivenessScorer:** Conducts FFT or Welch PSD analysis to detect a dominant physiological frequency peak and compute an SNR-based liveness score.
- **FaceEmbedder:** Extracts 512-dimensional facial embeddings (ArcFace/DeepFace) to verify identity similarity.
- **QualityAssessor:** Evaluates real-time blur, illumination, and frame rate consistency.
- **FusionEngine:** Integrates all outputs via decision rules or ML classifiers to determine the final Accept/Reject/Retry status.

## 3.3 Hardware/Software Mapping

A client-server distributed architecture powers the BioAuth system. Each software component is mapped to its matching hardware node in the UML deployment diagram below, which also displays the communication protocols between tiers.

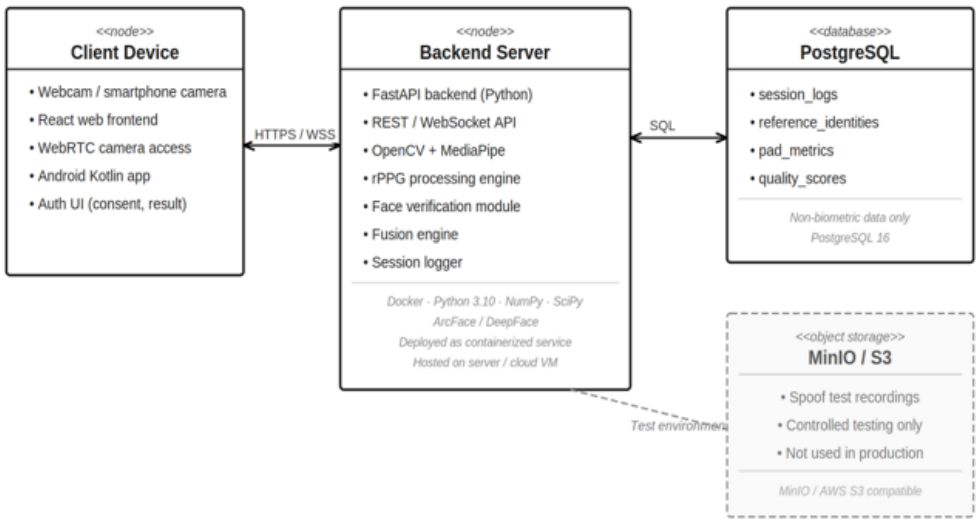



*Figure 2. UML deployment diagram*

Figure 2 illustrates the deployment structure and communication flow between the client device, backend server, and persistent storage components of the BioAuth platform.

- **Client Node:** Utilizes standard webcams or smartphone cameras through React/WebRTC for web interfaces and Kotlin-based native integration for Android devices.
- **Server Node:** The backend is implemented in Python and deployed as a containerized FastAPI service. Computer vision and signal processing operations utilize OpenCV, NumPy, SciPy, and MediaPipe.
- **Database Layer:** PostgreSQL is used for authentication logs, evaluation metrics, and system monitoring data.

### 3.4 Persistent Data Management

The BioAuth system's data management places a high priority on secure biometric handling and privacy. Without express user consent, all biometric inputs (including video frames and rPPG signals) are processed solely in volatile memory and are not permanently stored.

PostgreSQL is used to store performance metrics like APCER and BPCER computations as well as authentication session metadata for operational monitoring and administrative assessment. MinIO/S3 storage is only used in a different testing environment for experimental evaluation and controlled spoof-attack recordings.

### 3.5 Access Control and Security

In order to prevent unauthorized interception of biometric data during transmission, end-user authentication sessions use encrypted network communication (HTTPS/WSS) and temporary anonymous session generation. Role-based authentication methods limit access to the administrative dashboard so that only authorized operators can view monitoring data, evaluation metrics, and authentication logs. The system uses multi-factor authentication scoring and physiological liveness analysis in addition to traditional access control techniques to prevent spoofing attacks.

### 3.6 Global Software Control

The global software control flow follows a deterministic event-driven state machine architecture consisting of the following states:

1. **IDLE:** The system waits for the user to initiate authentication.
2. **CAPTURING:** A valid face is detected and video frames are accumulated for rPPG processing.
3. **PROCESSING:** The collected signals undergo filtering and frequency-domain analysis.
4. **EVALUATING:** The fusion engine combines liveness, facial similarity, and quality metrics to generate the authentication decision.
5. **Terminal States (ACCEPT / REJECT / RETRY):** The session terminates, the final result is returned to the client interface, and relevant session metadata is logged.

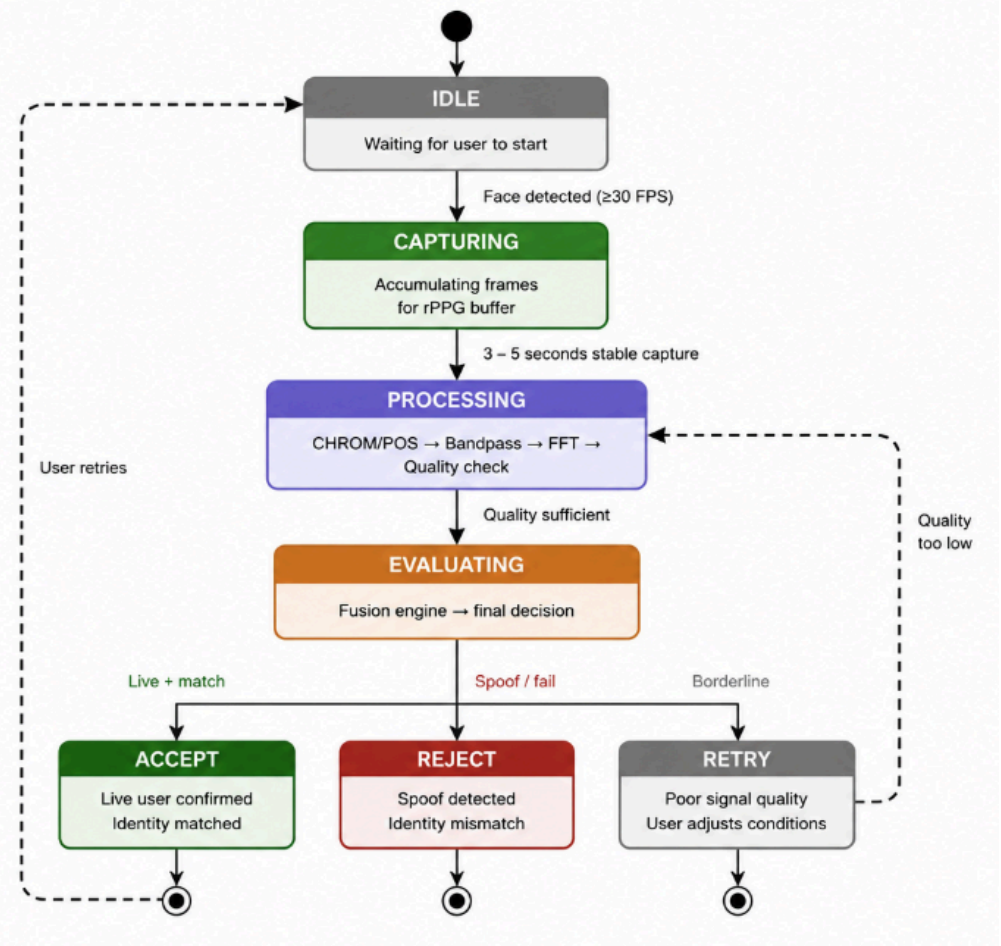



*Figure 3. Authentication State Machine*

The BioAuth authentication pipeline's global software control flow is depicted in Figure 3. Before generating a final authentication decision, the system moves through successive states such as IDLE, CAPTURING, PROCESSING, and EVALUATING. The session ends in one of three states: ACCEPT, REJECT, or RETRY, depending on liveness analysis, facial similarity, and input quality metrics. The retry flow caused by poor signal quality or unstable environmental conditions is also shown in the diagram.

### 3.7 Boundary Conditions

The BioAuth system is built to withstand adverse operational and environmental circumstances without unfairly penalizing authorized users. During authentication, the **QualityAssesso**r continuously keeps an eye on factors like frame stability, blur level, motion intensity, and illumination quality.

If the captured input does not satisfy the minimum requirements for reliable rPPG extraction and liveness analysis, the system gracefully transitions into a **RETRY** state instead of issuing an incorrect **REJECT** decision. In such cases, the user is provided with corrective guidance messages such as “Please improve lighting” or “Hold steady” to improve capture quality before reattempting authentication.

## 4. Subsystem Services

Through the backend architecture, the BioAuth system offers a number of subsystem-level services. These services are categorized based on their primary functions: physiological signal analysis, authentication decision support, and communication and session handling.

### 4.1 Authentication and Communication Services

The lifecycle of authentication sessions between the client and the backend system is managed by the **APIController Service**. It sends real-time guidance messages and final authentication decisions back to the client interface after receiving streaming video frames via REST/WebSocket communication and forwarding them to the relevant processing modules. This service serves as the primary conduit for communication between the backend pipeline and the frontend application.

### 4.2 Physiological Analysis Services

The **Face Analysis Service** uses MediaPipe-based processing to carry out Region of Interest (ROI) mapping, facial landmark extraction, and face detection. The **RPPG Processing Service** receives the chosen facial areas, such as the cheeks and forehead.

The **RPPG Processing Service** extracts physiological signals using CHROM and POS algorithms. It applies temporal filtering and frequency-domain analysis to identify pulse-related patterns and generate liveness-related metrics such as dominant pulse frequency and SNR-based confidence scores.

### 4.3 Verification and Monitoring Services

The **Face Verification Service** computes facial embeddings using ArcFace/DeepFace models and compares them with the enrolled identity data to calculate similarity scores.

The **FusionEngine Service** combines physiological liveness scores, facial similarity results, and quality assessment outputs to generate the final authentication decision as **Accept**, **Reject**, or **Retry**.

The **SessionLogger Service** uses PostgreSQL to store PAD-related evaluation data, decision outcomes, quality metrics, and non-biometric authentication metadata. Monitoring, audit trails, and system performance assessment are all supported by these logs.

## 5. Glossary

- **APCER:** Attack Presentation Classification Error Rate, the proportion of attack samples incorrectly classified as genuine.
- **ArcFace:** A deep learning-based facial recognition model that produces discriminative facial embeddings.
- **BPCER:** Bona Fide Presentation Classification Error Rate, the proportion of genuine user samples incorrectly classified as attacks.
- **CHROM:** Chrominance-based rPPG extraction algorithm used to isolate pulse-related color changes from RGB signals.
- **DeepFace:** A facial recognition and analysis framework used for face verification and embedding extraction.
- **Deepfake:** AI-generated synthetic media manipulating a person's likeness in video or images.
- **FFT:** Fast Fourier Transform, a frequency-domain analysis method used to identify dominant physiological pulse frequencies.
- **Fusion Engine:** A decision-making component that integrates multiple independent scores to produce a unified authentication verdict.
- **Liveness Detection:** The process of determining whether a biometric sample belongs to a biologically live person rather than a spoof artifact.
- **MediaPipe:** Google's cross-platform framework used for real-time face detection and facial landmark extraction.
- **PAD:** Presentation Attack Detection, the process of determining whether a biometric sample belongs to a real user or a spoofing attempt.
- **POS:** Plane Orthogonal to Skin, an rPPG signal extraction method based on skin-tone orthogonal projection.

- **ROI:** Region of Interest, selected facial areas such as the forehead and cheeks used for physiological signal extraction.
- **rPPG:** Remote Photoplethysmography, a non-contact technique used to extract physiological pulse signals from facial video by analyzing subtle skin color variations.
- **SNR:** Signal-to-Noise Ratio, a metric used to evaluate the quality and strength of the extracted physiological signal.

## 6. References


- [1] Association for Computing Machinery (ACM), *ACM Code of Ethics and Professional Conduct*, 2018. Available: https://www.acm.org/code-of-ethics
- [2] IEEE Computer Society, *Software Engineering Code of Ethics and Professional Practice*, 1999. Available: https://www.computer.org/education/code-of-ethics
- [3] Financial Crimes Enforcement Network (FinCEN), *Alert on Deepfake-Enabled Fraud Targeting Financial Institutions*, 2024. Available: https://www.fincen.gov/system/files/shared/FinCEN-Alert-DeepFakes-Alert508FINAL.pdf
- [4] W. Wang, A. C. den Brinker, S. Stuijk, and G. de Haan, *"Algorithmic Principles of Remote PPG,"* IEEE Transactions on Biomedical Engineering, vol. 64, no. 7, pp. 1479–1491, 2017. Available: https://pmc.ncbi.nlm.nih.gov/articles/PMC6797647/
- [5] ISO/IEC 30107-3:2017, *Information technology — Biometric presentation attack detection — Part 3: Testing and reporting*. Available: https://www.iso.org/standard/67381.html